

IT Security Standards

Version 3.0, issued by the Office of the Chief Information Security Officer. Effective 1 April 2026. These standards supersede the Information Security Policy, Version 5.2, in its entirety.

1. Status and Purpose

This document replaces the Information Security Policy, Version 5.2. Where these standards and that policy differ, these standards control from the effective date. System owners must align their systems with these standards within 90 days of the effective date.

The revision reflects current guidance from national cyber security agencies, which no longer recommends several long-standing practices.

2. Identity and Access

Access is granted on the principle of least privilege. Every account must be traceable to a named individual. Access rights are reviewed quarterly by the owning manager. Accounts unused for 90 days are disabled automatically.

Privileged access is granted just in time and expires after eight hours.

3. Authentication

Multi-factor authentication is required for all personnel on all systems that are reachable from outside the corporate network. Hardware security keys are the preferred second factor.

Password rotation on a fixed schedule is prohibited. Passwords are changed only after a confirmed or suspected compromise, because forced periodic rotation drives users towards weaker and more predictable credentials.

Passwords must be at least 14 characters long. Passwords are screened against a breached-credential list at the point they are set, and rejected if they appear in it.

4. Endpoint Standards

All laptops must have full-disk encryption enabled before issue. The approved endpoint detection agent must be installed and reporting. Operating system security updates must be applied within 14 days of release, and within 48 hours for critical vulnerabilities.

5. Logging and Monitoring

Application and access logs are retained for 13 months. The extended period aligns the standards with the Data Retention and Deletion Policy and supports investigation of slow-moving intrusions.

Security-relevant events are forwarded to the central logging platform within five minutes. Log integrity is protected by write-once storage.

6. Remote Access

Personnel may access Company systems remotely from any country, provided the device passes the compliance check at connection time. The approved country list is withdrawn; device posture replaces geography as the control.

All remote access is through the corporate virtual private network.

7. Exceptions

Exceptions to these standards require written approval from the Chief Information Security Officer and are recorded in the security exception register. Exceptions expire after 12 months and must be renewed.